

Индивидуальный проект № 4: Использование Nikto

Эйвази Мани

06.октябрь.2026

Содержание

Презентация по индивидуальному проекту № 4	2
Использование Nikto для сканирования безопасности веб-сервера	2
Цели и задачи работы	2
Цель лабораторной работы	2
Процесс выполнения лабораторной работы	3
Шаг 1. Проверка установки Nikto	3
Шаг 2. Первый запуск сканирования	4
Шаг 3. Обнаруженные проблемы конфигурации	5
Шаг 4. Сохранение отчёта в формате HTML	7
Шаг 5. Анализ итогового отчёта	8
Шаг 6. Детализация обнаруженных находок	9
Выводы по проделанной работе	10
Вывод	10

Презентация по индивидуальному проекту № 4

Использование Nikto для сканирования безопасности веб-сервера

Цели и задачи работы

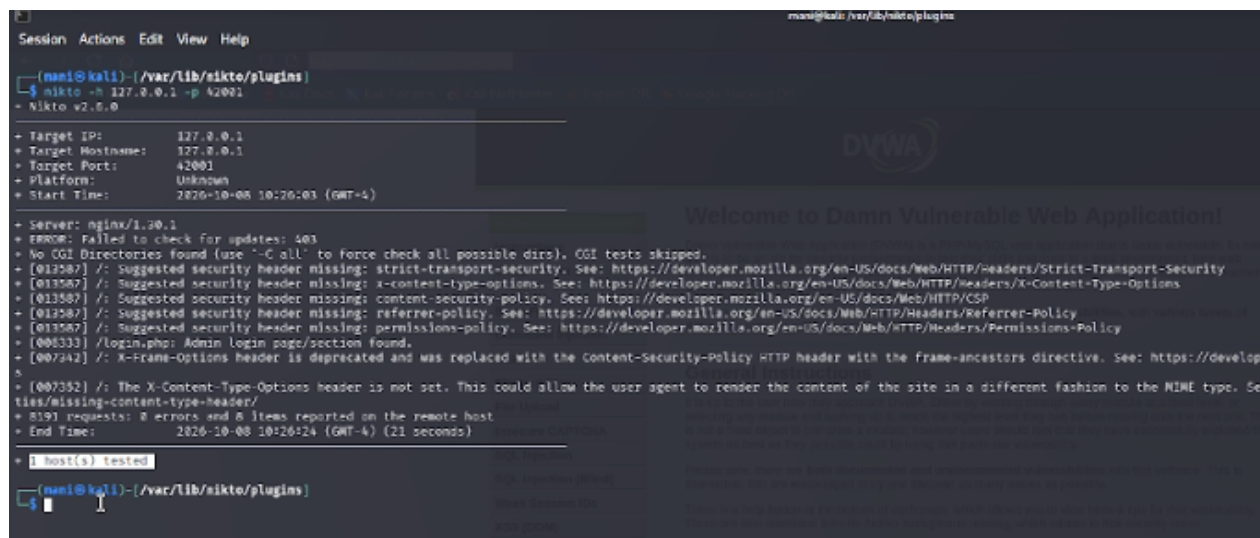
Цель лабораторной работы

Освоить практические навыки работы со сканером безопасности веб-серверов **Nikto** и продемонстрировать его возможности по выявлению типовых проблем конфигурации на примере уязвимого приложения DVWA, развёрнутого в локальной среде Kali Linux.

Процесс выполнения лабораторной работы

Шаг 1. Проверка установки Nikto

Перед началом сканирования убеждаемся, что Nikto корректно установлен в системе. Переходим в директорию плагинов `/var/lib/nikto/plugins` и запускаем команду `nikto -h 127.0.0.1 -p 42001`. В выводе отображается версия **Nikto v2.6.0**, что подтверждает готовность инструмента к работе.



```
Session Actions Edit View Help
man@kali: /var/lib/nikto/plugins
$ nikto -h 127.0.0.1 -p 42001
+ Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 42001
+ Platform: Unknown
+ Start Time: 2020-10-08 10:20:03 (GMT+4)

+ Server: nginx/1.20.1
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [012507] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013507] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013507] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
+ [013507] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013507] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [006333] /login.php: Admin login page/section found.
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ 8191 requests: 0 errors and 6 items reported on the remote host
+ End Time: 2020-10-08 10:20:24 (GMT+4) (21 seconds)

+ 1 host(s) tested

man@kali: /var/lib/nikto/plugins
$
```

Рис. 1 — Проверка версии Nikto

Шаг 2. Первый запуск сканирования

Выполняем сканирование локального веб-сервера DVWA с указанием порта 42001, на котором работает приложение:

```
nikto -h 127.0.0.1 -p 42001
```

Nikto выводит информацию о целевом хосте: IP-адрес 127.0.0.1, порт 42001, версию серверного ПО nginx/1.30.1. Начинается последовательная проверка сервера по базе известных сигнатур.

```
(kali@kali)~[~/var/lib/nikto/plugins]
$ nikto -h 127.0.0.1 -p 42001 -o ~/nikto_dvwa_report.html -format html
- nikto v2.0.0

+-----+-----+
| Target IP:          | 127.0.0.1 |
| Target Hostname:    | 127.0.0.1 |
| Target Port:        | 42001     |
| Platform:           | Unknown   |
| Start Time:         | 2020-10-08 10:26:50 (GMT+4) |
+-----+-----+

- Servers: nginx/1.30.1
- ssnore: failed to check for updates: 403
- No CGI Directories found (use '-C all' to force check all possible dirs), CGI tests skipped.
- [001587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
- [001587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/Strict-Transport-Security
- [001587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/Permissions-Policy
- [001587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/X-Content-Type-Options
- [001587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/referrer-policy
- [000333] /login.php: Admin login page/section found.
- [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
- [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
- 4391 requests: 2 errors and 6 items reported on the remote host
- End Time:      2020-10-08 10:27:13 (GMT+4) (23 seconds)
```

Рис. 2 — Запуск сканирования Nikto

Шаг 3. Обнаруженные проблемы конфигурации

В процессе сканирования Nikto обнаружил **8 проблем** на целевом сервере. Все они относятся к **отсутствующим или устаревшим HTTP-заголовкам безопасности**:

- **Strict-Transport-Security** — не задан заголовок HSTS;
- **X-Content-Type-Options** — защита от MIME-sniffing отсутствует;
- **Permissions-Policy** — не задана политика разрешений браузера;
- **Content-Security-Policy** — не задана политика безопасности контента;
- **Referrer-Policy** — не задана политика передачи referrer;
- **Admin login page found** — обнаружена страница входа (/login.php);
- **X-Frame-Options** — устаревший заголовок, заменён на CSP;
- **Content-Type** — не задан явно, риск MIME-confusion.

127.0.0.1 / 127.0.0.1 port 42001	
Target IP	127.0.0.1
Target hostname	127.0.0.1
Target Port	42001
HTTP Server	nginx/1.30.1
Site Link (Name)	http://127.0.0.1:42001/
Site Link (IP)	http://127.0.0.1:42001/
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: strict-transport-security.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: x-content-type-options.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: permissions-policy.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: content-security-policy.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: referrer-policy.
Link	http://127.0.0.1:42001/

Рис. 3 — Список обнаруженных Nikto проблем

Шаг 4. Сохранение отчёта в формате HTML

Для формирования итогового отчёта повторно запускаем сканирование с сохранением результатов в файл:

```
nikto -h 127.0.0.1 -p 42001 -o /home/mani/nikto_dvwa_report.html -Format htm
```

По завершении Nikto выводит итоговую статистику: **8191** запрос, **0** ошибок, **8** обнаруженных проблем, время сканирования — **23 секунды**. Результаты сохранены в HTML-файл для дальнейшего анализа и подготовки отчёта.

Host Summary	
Start Time	2026-10-08 10:26:50
End Time	2026-10-08 10:27:13
Elapsed Time	23 seconds
Statistics	8191 requests, 0 errors, 8 findings

Scan Summary	
Software Details	Nikto 2.6.0
CLI Options	-h 127.0.0.1 -p 42001 -o /home/mani/nikto_dvwa_report.html -Format htm
Hosts Tested	1
Start Time	Thu Oct 8 10:26:50 2026
End Time	Thu Oct 8 10:27:13 2026
Elapsed Time	23 seconds

© 2008 Chris Sullo

Рис. 4 — Сохранение отчёта Nikto в HTML

Шаг 5. Анализ итогового отчёта

Открываем сохранённый HTML-отчёт в браузере. В верхней части отображается сводка **Host Summary** и **Scan Summary** с ключевыми метриками: целевой хост, порт, версия сервера, количество запросов, найденных проблем и общее время сканирования. Здесь же указана полная команда запуска и версия используемого инструмента.

Рис. 5 — Сводка Host Summary и Scan Summary

Шаг 6. Детализация обнаруженных находок

В нижней части HTML-отчёта приводится детальное описание каждой находки. Для каждой проблемы указываются URI, HTTP-метод, описание и ссылка на официальную документацию Mozilla (MDN). Например, для отсутствующего заголовка `Strict-Transport-Security` указана ссылка на соответствующую статью MDN с объяснением назначения этого заголовка.

Рис. 6 — Детализация находок в HTML-отчёте

Выводы по проделанной работе

Вывод

В ходе индивидуального проекта № 4 был изучен и практически применён **сканер безопасности веб-серверов Nikto**. С его помощью выполнено сканирование уязвимого приложения DVWA, развёрнутого на порту 42001 локального сервера. Nikto выполнил **8191 HTTP-запрос за 23 секунды**, не встретив ошибок, и обнаружил **8 проблем**, связанных с отсутствием или устареванием HTTP-заголовков безопасности.

Были освоены ключевые параметры команды Nikto: `-h` для указания хоста, `-p` для порта, `-o` для сохранения отчёта и `-Format htm` для выбора формата. Полученный HTML-отчёт содержит структурированную информацию: сводку сканирования, статистику и детальное описание каждой находки со ссылками на документацию.

Основной вывод работы: **Nikto — эффективный инструмент для быстрой оценки конфигурации веб-сервера**, однако он не заменяет специализированные сканеры уязвимостей приложений. Для комплексного аудита безопасности необходимо сочетать Nikto с инструментами динамического анализа (Burp Suite, OWASP ZAP) и ручным тестированием.